



Blackgate - A Blockchain-based Identity & Authentication System

Project Team

Awais Shahid 21I-2764
Abdullah Abubaker 21I-1917

Session 2021-2025

Supervised by

Dr. Muhammad Asim

Co-Supervised by

Ms. Noor-ul-Ain



Department of Cyber Security

**National University of Computer and Emerging Sciences
Islamabad, Pakistan**

June, 2025

Contents

1	Introduction	1
1.1	Problem Statement	2
1.2	Scope	2
1.3	Modules	3
1.3.1	User and Mobile Authentication Interface	3
1.3.2	Administrative Dashboard	3
1.3.3	AI Contextual Monitoring Engine	3
1.3.4	Blockchain-Based Identity Management (BDIM)	3
1.4	User Classes and Characteristics	4
2	Project Requirements	5
2.1	Use Cases	5
2.1.1	UC-001: User Registration	5
2.1.2	UC-002: User Authentication	5
2.1.3	UC-003: Administrative Dashboard Monitoring	6
2.1.4	UC-004: Trust Score Assessment	6
2.1.5	UC-005: Blockchain-Based Identity Management	6
2.1.6	UC-006: Passwordless Login Implementation	6
2.1.7	UC-007: User Activity Log Review	7
2.1.8	UC-008: Account Recovery Process	7
2.2	Extended Use Cases (UCX)	8
2.2.1	UCX-001: User Registration	8
2.2.2	UCX-002: User Authentication	9
2.2.3	UCX-003: Administrative Dashboard Monitoring	10
2.2.4	UCX-004: Trust Score Assessment	11
2.2.5	UCX-005: Blockchain-Based Identity Management	12
2.2.6	UCX-006: Passwordless Login Implementation	13
2.2.7	UCX-007: User Activity Log Review	14
2.2.8	UCX-008: Account Recovery Process	15
2.3	Functional Requirements	16
2.3.1	User Registration and Authentication	16
2.3.2	Administrative Dashboard	16

2.3.3	AI Contextual Monitoring Engine	17
2.3.4	Blockchain-Based Identity Management	17
2.3.5	User Account Management	17
2.4	Non-Functional Requirements	18
2.4.1	Performance	18
2.4.2	Scalability	18
2.4.3	Reliability	19
2.4.4	Usability	19
2.4.5	Maintainability	19
2.4.6	Capacity	19
2.4.7	Security	20
2.5	Domain Model	20
2.5.1	DM-001 - Domain Model Diagram	20
3	System Overview	21
3.1	Architectural Design	21
3.1.1	Application Layer	21
3.1.2	Verification Layer	21
3.1.3	Blockchain Layer	22
3.1.4	AI Behavior Analysis	22
3.1.5	Flow of Events	22
3.2	Design Models	23
3.2.1	Activity Diagrams for Use Cases	23
3.2.1.1	AD-XXX - Key	23
3.2.1.2	AD-001 - User Login	24
3.2.1.3	AD-002 - User Authentication	25
3.2.1.4	AD-003 - Administrative Dashboard Monitoring	26
3.2.1.5	AD-004 - Trust Score Assessment	27
3.2.1.6	AD-005 - Blockchain-Based Identity Management	28
3.2.1.7	AD-006 - Passwordless Login Implementation	29
3.2.1.8	AD-007 - User Activity Log Review	30
3.2.1.9	AD-008 - Account Recovery Process	31
3.2.2	Sequence Diagrams	32
3.2.3	Data Flow Diagram	33
3.2.3.1	Data Flow Diagram - Level 0	33
3.2.3.2	Data Flow Diagram - Level 1	34
3.3	Data Design	35
3.3.1	Entity Relationship Diagram	35
	References	36

List of Figures

2.1	DM-001 - Domain Model Diagram	20
3.1	SA-001 - System Architecture Diagram	23
3.2	AD-XXX - Activity Diagram Key	23
3.3	AD-001 - User Login	24
3.4	AD-002 - User Authentication	25
3.5	AD-003 - Administrative Dashboard Monitoring	26
3.6	AD-004 - Trust Score Assessment	27
3.7	AD-005 - Blockchain-Based Identity Management	28
3.8	AD-006 - Passwordless Login Implementation	29
3.9	AD-007 - User Activity Log Review	30
3.10	AD-008 - Account Recovery Process	31
3.11	SSD-001 - System Sequence Diagram	32
3.12	DFD-000 - Context Diagram	33
3.13	DFD-001 - Context Diagram (Exploded)	34
3.14	ERD-001 - Entity Relationship Diagram	35

List of Tables

1.1	Stakeholders in BlackGate	4
2.1	UC-001: User Registration	5
2.2	UC-002: User Authentication	5
2.3	UC-003: Administrative Dashboard Monitoring	6
2.4	UC-004: Trust Score Assessment	6
2.5	UC-005: Blockchain-Based Identity Management	6
2.6	UC-006: Passwordless Login Implementation	6
2.7	UC-007: User Activity Log Review	7
2.8	UC-008: Account Recovery Process	7
2.9	UCX-001: User Registration	8
2.10	UCX-002: User Authentication	9
2.11	UCX-003: Administrative Dashboard Monitoring	10
2.12	UCX-004: Trust Score Assessment	11
2.13	UCX-005: Blockchain-Based Identity Management	12
2.14	UCX-006: Passwordless Login Implementation	13
2.15	UCX-007: User Activity Log Review	14
2.16	UCX-008: Account Recovery Process	15

Chapter 1

Introduction

The project described in this document is a **stateless decentralized identity & access management (SD-IAM) system**. This system leverages blockchain technology to manage decentralized identities securely and efficiently, reducing storage requirements and enhancing privacy. The SD-IAM system provides a scalable, secure, and user-friendly solution for managing user identities, access control, and authentication in enterprise environments all while ensuring data integrity and privacy.

Intended Readers

1. **FYP Coordinators:** To oversee project alignment with academic goals and evaluate overall progress.
2. **FYP Committee:** To assess the project's objectives, security features, and implementation strategies for enterprise IAM systems.
3. **End Users (Employees, Managers & Admins):** To learn how their credentials will be securely managed, verified, and protected in an enterprise environment.
4. **Testers:** To evaluate the system's performance, security features, and verification processes, ensuring the identity management system operates as intended.
5. **Deployment Staff:** Individuals and organizations interested in understanding how to effectively deploy the identity management system within their own environments.

1.1 Problem Statement

In modern enterprises, managing user identities and access across diverse systems is complex, prone to security risks, and resource-intensive. Traditional Identity and Access Management (IAM) systems often face challenges such as inefficient scalability, fragmented user identity data, and security vulnerabilities like unauthorized access or identity theft. Our IAM solution addresses these problems by providing a decentralized, blockchain-enabled identity management system that enhances security, scalability, and efficiency. It ensures secure authentication and access control across various applications while reducing the risk of identity theft, data breaches, and unauthorized access. By leveraging cryptographic techniques and decentralized identifiers (DIDs), our system improves user privacy and simplifies identity management for both users and administrators by using the following paper for support [1].

1.2 Scope

BlackGate is designed to provide a robust and secure identity and access management solution. It offers several key functionalities, including:

- Passwordless login
- Single Sign-On (SSO)
- Multi-Factor Authentication (MFA)
- User Context analysis for anomaly detection
- Dedicated dashboards for both admins and employees to manage identities effectively
- Secure user authentication based on Decentralized identifiers (DIDs) & verifiable Credentials (VCs)

To ensure seamless integration with existing systems, BlackGate supports:

- LDAP and directory services
- APIs for third-party integration
- Federated Identity Management (FIM) based on SAML/OAuth/OpenID Connect

However, it is important to note that:

- BlackGate will not provide explicit recommendations for access control strategies.

- Its primary focus is on facilitating identity management rather than dictating specific security policies.

1.3 Modules

1.3.1 User and Mobile Authentication Interface

- Enable mobile-friendly authentication with passwordless login and Multi-Factor Authentication(MFA).
- Offer real-time notifications and account management through dedicated dashboards for users.
- Provide access through Federated Identity Management (FIM) based on SAML/OAuth/OpenID Connect.
- Implement secure user authentication based on Decentralized Identifiers (DIDs) and Verifiable Credentials (VCs).

1.3.2 Administrative Dashboard

- Monitor user sessions and access logs.
- Configure and enforce authentication policies, including Single Sign-On (SSO).

1.3.3 AI Contextual Monitoring Engine

- Revoke access based on dynamically calculated trust scores and user context analysis.
- Monitor user behavior and contextual data to analyze anomalies and assess trust scores.

1.3.4 Blockchain-Based Identity Management (BDIM)

- Manage identities and authentication data using a decentralized approach.
- Ensure compatibility with LDAP and directory services for seamless integration.
- Maintain the integrity of authentication records through the use of blockchain technology.

1.4 User Classes and Characteristics

User Class	Description
Compliance & Audit Professionals	• Ensure adherence to regulations and standards through audits and assessments. • Provide recommendations for improving compliance with regulatory requirements.
Blockchain Network Operators	• Responsible for network maintenance, health monitoring, and governance. • Manage consensus mechanisms and facilitate blockchain protocol updates.
Developers	• Design and deploy smart contracts, implement security protocols. • Develop interfaces for end users and service providers.
Service Providers	• Manage access permissions and integrate IAM for seamless experience. • Request identity verification and ensure smooth service flow.
End Users	• Manage personal data and verifiable credentials. • Share credentials and monitor access permissions.
Identity Verifiers	• Authenticate user credentials and verify them on the blockchain. • Enforce access control based on verification results.
Regulatory Authorities	• Set policies and standards for identity management. • Monitor compliance with data protection laws and best practices.
Privacy Advocates	• Promote user privacy and ethical data handling practices. • Advocate for user rights and enhance privacy measures.
Identity Issuers	• Generate, manage, and revoke verifiable credentials. • Maintain records of issued credentials and ensure trustworthiness.
Technology Vendors	• Supply IAM solutions and support system integration. • Offer maintenance, updates, and innovation in identity management.
Community Stakeholders	• Participate in governance and evolution of the IAM system. • Provide feedback and collaborate on system improvements.

Table 1.1: Stakeholders in BlackGate

Chapter 2

Project Requirements

This chapter describes the Use-Cases, Extended Use-Cases as well as Functional and non-functional requirements of the project along with the Data Domain Model

2.1 Use Cases

2.1.1 UC-001: User Registration

Use Case ID	UC-001: User Registration
Actor	End User, System
Type	Primary
Description	The user registers with a valid email or phone number and receives a Decentralized Identifier (DID) and Verifiable Credential (VC).

Table 2.1: UC-001: User Registration

2.1.2 UC-002: User Authentication

Use Case ID	UC-002: User Authentication
Actor	End User, System
Type	Primary
Description	The user authenticates using a valid Decentralized Identifier (DID) and Verifiable Credential (VC) to access the system.

Table 2.2: UC-002: User Authentication

2.1.3 UC-003: Administrative Dashboard Monitoring

Use Case ID	UC-003: Administrative Dashboard Monitoring
Actor	Administrator, System
Type	Secondary
Description	The administrator monitors real-time user session data, access logs, and blockchain transaction logs via the dashboard.

Table 2.3: UC-003: Administrative Dashboard Monitoring

2.1.4 UC-004: Trust Score Assessment

Use Case ID	UC-004: Trust Score Assessment
Actor	System, End User
Type	Primary
Description	The system continuously evaluates user behavior and updates their trust score, potentially revoking access if the score falls below a threshold.

Table 2.4: UC-004: Trust Score Assessment

2.1.5 UC-005: Blockchain-Based Identity Management

Use Case ID	UC-005: Blockchain-Based Identity Management
Actor	System, End User
Type	Primary
Description	The system manages user identity updates on the blockchain to ensure integrity and security of credentials.

Table 2.5: UC-005: Blockchain-Based Identity Management

2.1.6 UC-006: Passwordless Login Implementation

Use Case ID	UC-006: Passwordless Login Implementation
Actor	End User, System
Type	Primary
Description	The user logs in using a one-time code without a password for authentication.

Table 2.6: UC-006: Passwordless Login Implementation

2.1.7 UC-007: User Activity Log Review

Use Case ID	UC-007: User Activity Log Review
Actor	End User, System
Type	Secondary
Description	The user reviews a log of their recent account activities, including blockchain transactions.

Table 2.7: UC-007: User Activity Log Review

2.1.8 UC-008: Account Recovery Process

Use Case ID	UC-008: Account Recovery Process
Actor	End User, System
Type	Secondary
Description	The user recovers access to their account after losing access, with the process securely recorded on the blockchain.

Table 2.8: UC-008: Account Recovery Process

2.2 Extended Use Cases (UCX)

2.2.1 UCX-001: User Registration

Use Case ID	UCX-001: User Registration
Scope	User Account Creation
Actor	End User, System
Level	User Goal
Priority	High
Stakeholders & Interests	Users (want seamless registration), Admins (want reliable user management)
Preconditions	The user has a valid email or phone number.
Postconditions	The user is registered and provided with a Decentralized Identifier (DID) and Verifiable Credential (VC).
Main Success Scenario	1. The user navigates to the registration page. 2. The system prompts the user to enter their email or phone number. 3. The user submits their information. 4. The system generates a DID and VC for the user. 5. The system sends a confirmation link or code to the user's email or phone. 6. The user follows the link or enters the code to confirm registration.
Extensions	If the provided information is invalid, the system displays an error message and prompts the user to retry.
Special Requirements	Secure validation of contact information.
Technology	Web and mobile interfaces, DID technology, Verifiable Credentials
Frequency of Occurrence	High, during user onboarding.

Table 2.9: UCX-001: User Registration

2.2.2 UCX-002: User Authentication

Use Case ID	UCX-002: User Authentication
Scope	User Login
Actor	End User, System
Level	User Goal
Priority	High
Stakeholders & Interests	Users (want secure, fast login), Admins (want secure access control)
Preconditions	The user has a valid DID and VC.
Postconditions	The user is authenticated and granted access to the system.
Main Success Scenario	1. The user initiates the authentication process via the mobile authentication interface. 2. The system requests the user's DID and VC. 3. The user submits their DID and VC. 4. The system verifies the DID and VC against the blockchain. 5. Upon successful verification, the system provides an authentication token. 6. The user is granted access to the system and receives a real-time notification.
Extensions	If verification fails, the system displays an error message and prompts the user to retry.
Special Requirements	Strong encryption during DID and VC verification.
Technology	Blockchain, DID, Verifiable Credentials, Authentication Tokens
Frequency of Occurrence	High, during user logins.

Table 2.10: UCX-002: User Authentication

2.2.3 UCX-003: Administrative Dashboard Monitoring

Use Case ID	UCX-003: Administrative Dashboard Monitoring
Scope	Admin Monitoring
Actor	Administrator, System
Level	User Goal
Priority	Medium
Stakeholders & Interests	Admins (need real-time visibility), Compliance (audit trail)
Preconditions	The administrator is logged into the administrative dashboard.
Postconditions	The administrator can view real-time user session data, access logs, and blockchain transaction logs.
Main Success Scenario	1. The administrator accesses the monitoring section of the dashboard. 2. The system retrieves and displays current user sessions, access logs, and blockchain-based transaction logs related to identity updates. 3. The administrator can filter logs by date, user, action, or blockchain transaction type. 4. The system provides analytics and reports on user activity and blockchain-based actions.
Extensions	If the system encounters a failure retrieving data, it displays an error message and suggests refreshing the page.
Special Requirements	High availability, accurate real-time data retrieval.
Technology	Web dashboard, blockchain-based identity logging
Frequency of Occurrence	Medium, during admin oversight.

Table 2.11: UCX-003: Administrative Dashboard Monitoring

2.2.4 UCX-004: Trust Score Assessment

Use Case ID	UCX-004: Trust Score Assessment
Scope	Risk-based Authentication
Actor	System, End User
Level	System Subprocess
Priority	High
Stakeholders & Interests	Users (need secure access), System Owners (need to manage risk)
Preconditions	The user has logged into the system.
Postconditions	The system calculates and updates the user's trust score.
Main Success Scenario	1. The system continuously monitors user behavior and contextual data. 2. The system compares current behavior against predefined parameters to calculate a trust score. 3. If the trust score falls below a specified threshold, the system automatically revokes access. 4. The user receives a notification regarding the revocation of access.
Extensions	If the user's behavior improves, the system re-evaluates the trust score and may restore access.
Special Requirements	AI-driven behavior monitoring.
Technology	AI-based risk analysis, trust score computation
Frequency of Occurrence	Ongoing, during user sessions.

Table 2.12: UCX-004: Trust Score Assessment

2.2.5 UCX-005: Blockchain-Based Identity Management

Use Case ID	UCX-005: Blockchain-Based Identity Management
Scope	Identity Updates
Actor	System, End User
Level	User Goal
Priority	Medium
Stakeholders & Interests	Users (want accurate records), Admins (need auditability), Compliance (require immutable records)
Preconditions	The user is interacting with the identity management features of the system.
Postconditions	The user's identity management actions are recorded on the blockchain.
Main Success Scenario	1. The user initiates an identity management action (e.g., updating credentials). 2. The system processes the request and updates the identity on the blockchain. 3. The system ensures the integrity of the updated record and prevents unauthorized modifications. 4. The action is logged, and an audit trail is generated for compliance.
Extensions	If there's an error during the update, the system notifies the user and rolls back the transaction.
Special Requirements	Immutable blockchain logs.
Technology	Blockchain, identity management tools
Frequency of Occurrence	Medium, during identity updates.

Table 2.13: UCX-005: Blockchain-Based Identity Management

2.2.6 UCX-006: Passwordless Login Implementation

Use Case ID	UCX-006: Passwordless Login Implementation
Scope	Passwordless Authentication
Actor	End User, System
Level	User Goal
Priority	High
Stakeholders & Interests	Users (prefer ease of access), Admins (want strong authentication)
Preconditions	The user has opted for passwordless authentication.
Postconditions	The user is authenticated without using a password.
Main Success Scenario	1. The user selects the passwordless login option on the mobile interface. 2. The system sends a one-time code to the user's registered email or phone number. 3. The user enters the one-time code into the system. 4. The system verifies the code and authenticates the user.
Extensions	If the code is incorrect, the system prompts the user to request a new code.
Special Requirements	Secure one-time code generation and delivery.
Technology	One-time password (OTP), mobile/web interfaces
Frequency of Occurrence	High, during user logins with passwordless option.

Table 2.14: UCX-006: Passwordless Login Implementation

2.2.7 UCX-007: User Activity Log Review

Use Case ID	UCX-007: User Activity Log Review
Scope	Activity Logging
Actor	End User, System
Level	User Goal
Priority	Medium
Stakeholders & Interests	Users (want transparency on their activities), Admins (require logs for compliance)
Preconditions	The user is logged into their account.
Postconditions	The user can view a log of their recent account activities, including blockchain transactions.
Main Success Scenario	1. The user navigates to the activity log section of their account. 2. The system retrieves and displays the user's recent activities, including logins, changes made to their account, and blockchain transaction logs related to identity management. 3. The user can filter the log by date, type of activity, or blockchain-specific events (e.g., credential updates).
Extensions	If the system encounters an error retrieving the log, the system displays an error message and prompts the user to retry.
Special Requirements	Comprehensive activity logs with blockchain transparency.
Technology	Blockchain, activity log management tools
Frequency of Occurrence	Medium, during user reviews of their account.

Table 2.15: UCX-007: User Activity Log Review

2.2.8 UCX-008: Account Recovery Process

Use Case ID	UCX-008: Account Recovery Process
Scope	Account Recovery
Actor	End User, System
Level	User Goal
Priority	High
Stakeholders & Interests	Users (need secure recovery process), Admins (ensure secure identity recovery)
Preconditions	The user has lost access to their account.
Postconditions	The user can regain access to their account, and the recovery process is securely recorded on the blockchain.
Main Success Scenario	1. The user selects the account recovery option on the login page. 2. The system prompts the user to provide their registered email or phone number. 3. The user submits the information. 4. The system sends a recovery link or code to the registered contact. 5. The user follows the link or enters the code to reset their authentication method, and the successful recovery is recorded on the blockchain for future reference.
Extensions	If the provided information does not match any account, the system displays an error message and prompts the user to retry.
Special Requirements	Secure recovery mechanism, blockchain logging.
Technology	Blockchain, account recovery protocols
Frequency of Occurrence	Low, triggered by loss of account access.

Table 2.16: UCX-008: Account Recovery Process

2.3 Functional Requirements

2.3.1 User Registration and Authentication

- **FR-001:** The system shall allow users to register by entering a valid email address or phone number.
- **FR-002:** The system shall generate a Decentralized Identifier (DID) and Verifiable Credential (VC) upon successful registration.
- **FR-003:** The system shall send a confirmation link or code to the user's registered email or phone number for verification.
- **FR-004:** The system shall require users to authenticate using their DID and VC.
- **FR-005:** The system shall verify the submitted DID and VC against the blockchain before granting access.
- **FR-006:** The system shall provide an authentication token upon successful verification.
- **FR-007:** The system shall support secure user authentication using Decentralized Identifiers (DIDs) and Verifiable Credentials (VCs).
- **FR-008:** The system shall implement Federated Identity Management (FIM) to facilitate user access through SAML, OAuth, or OpenID Connect protocols.
- **FR-009:** The system shall provide a mobile-friendly authentication interface that allows users to log in without passwords, utilizing advanced authentication methods.
- **FR-010:** The system shall offer real-time notifications for account activities and allow users to manage their accounts through dedicated dashboards.
- **FR-023:** The system shall provide a passwordless login option for users.
- **FR-024:** The system shall generate and send a one-time code to the user's registered email or phone number for authentication.
- **FR-025:** The system shall authenticate users based on the verification of the one-time code.

2.3.2 Administrative Dashboard

- **FR-011:** The system shall enable administrators to access a monitoring dashboard displaying real-time user session data, access logs, and blockchain transaction logs.

- **FR-012:** The system shall allow administrators to filter logs by date, user, action, or transaction type.
- **FR-013:** The system shall generate analytics and reports on user activity and blockchain actions to help administrators assess system usage and security posture.

2.3.3 AI Contextual Monitoring Engine

- **FR-014:** The system shall continuously monitor user behavior and contextual data to calculate a trust score.
- **FR-015:** The system shall automatically revoke user access if their trust score falls below a specified threshold.
- **FR-016:** The system shall notify users when their access is revoked due to a low trust score.
- **FR-031:** The system shall leverage AI algorithms to continuously improve the accuracy of trust score assessments based on evolving user behavior patterns.

2.3.4 Blockchain-Based Identity Management

- **FR-017:** The system shall record user identity updates on the blockchain to ensure data integrity and security.
- **FR-018:** The system shall prevent unauthorized modifications to identity records on the blockchain.
- **FR-019:** The system shall log identity management actions and generate an audit trail for compliance purposes.

2.3.5 User Account Management

- **FR-020:** The system shall allow users to view and update their account information securely.
- **FR-021:** The system shall validate user-submitted updates before applying changes to the blockchain.
- **FR-022:** The system shall notify users when their account information has been successfully updated.
- **FR-026:** The system shall allow users to view their recent account activity logs, including blockchain transactions.

- **FR-027:** The system shall enable users to filter their activity logs by date, type of activity, or blockchain events.
- **FR-028:** The system shall provide an account recovery option for users who have lost access.
- **FR-029:** The system shall send a recovery link or code to the user's registered email or phone number for resetting their authentication method.
- **FR-030:** The system shall securely record the account recovery process on the blockchain.

2.4 Non-Functional Requirements

2.4.1 Performance

1. The system shall support a minimum of 1,000 concurrent user sessions without performance degradation, ensuring high availability during peak usage.
2. The system shall respond to user authentication requests within 2 seconds under normal load conditions to provide a seamless user experience.
3. The system shall process identity verification requests and provide feedback within 5 seconds to maintain user engagement.
4. The application must minimize latency in authentication and identity management processes, ensuring responsiveness to user actions.
5. Performance benchmarks for blockchain-related operations shall be established, such that 95% of identity verification requests involving blockchain transactions shall be confirmed within 4 seconds under standard network conditions.

2.4.2 Scalability

1. The system shall be designed for horizontal scalability to accommodate increasing user loads and maintain performance without significant reconfiguration.
2. The system shall allow for seamless integration of new identity providers and authentication methods, ensuring uninterrupted access for users.
3. The application must efficiently handle an increased volume of blockchain transactions as the user base grows, maintaining performance and security.

2.4.3 Reliability

1. The system shall achieve an uptime of 99.9% over any given month, excluding scheduled maintenance, to ensure continuous availability for users.
2. The system shall have a robust disaster recovery plan to maintain data integrity and system availability in the event of a failure, particularly regarding blockchain operations.
3. The application must include proper error handling and backup mechanisms, ensuring reliability in identity management and authentication processes.
4. Reliability metrics shall be defined, including Mean Time Between Failures (MTBF) for blockchain operations, with clear strategies for error detection and correction.

2.4.4 Usability

1. The system shall provide a user-friendly interface that is intuitive for both end users and administrators, requiring minimal training for effective usage.
2. The system shall offer comprehensive help documentation, tooltips, and tutorials to assist users in navigating and managing their identities.
3. The application should present a simple and visually appealing interface that facilitates interaction with blockchain-based functionalities.
4. Usability requirements shall address ease of learning, error avoidance, efficiency of interactions, and accessibility for all users.
5. Users shall be able to retrieve previous authentication attempts or identity verifications with a single interaction, enhancing user experience.

2.4.5 Maintainability

1. The system should be designed for easy maintenance, with each module developed as a standalone subsystem, allowing for independent updates and maintenance, particularly for blockchain components.
2. Code and architecture shall follow industry best practices to ensure maintainability and facilitate future enhancements or modifications.

2.4.6 Capacity

1. The system should have the capability to store vast amounts of user data, including blockchain transaction records, while ensuring scalability and performance as data

volume increases.

2. The application shall support efficient data retrieval and storage mechanisms, optimizing access times even with large datasets.

2.4.7 Security

1. The system shall implement stringent security measures to protect user data and authentication processes, particularly concerning blockchain transactions and user identities.
2. Security metrics shall be defined in terms of the effort, skill level, or time required to breach the system or manipulate blockchain records, ensuring a robust security posture.
3. The system shall employ advanced authentication methods and data protection techniques to enhance overall security without reliance on traditional password-based systems.
4. Regular security assessments and audits shall be conducted to identify vulnerabilities and improve the security framework of the system.

2.5 Domain Model

2.5.1 DM-001 - Domain Model Diagram

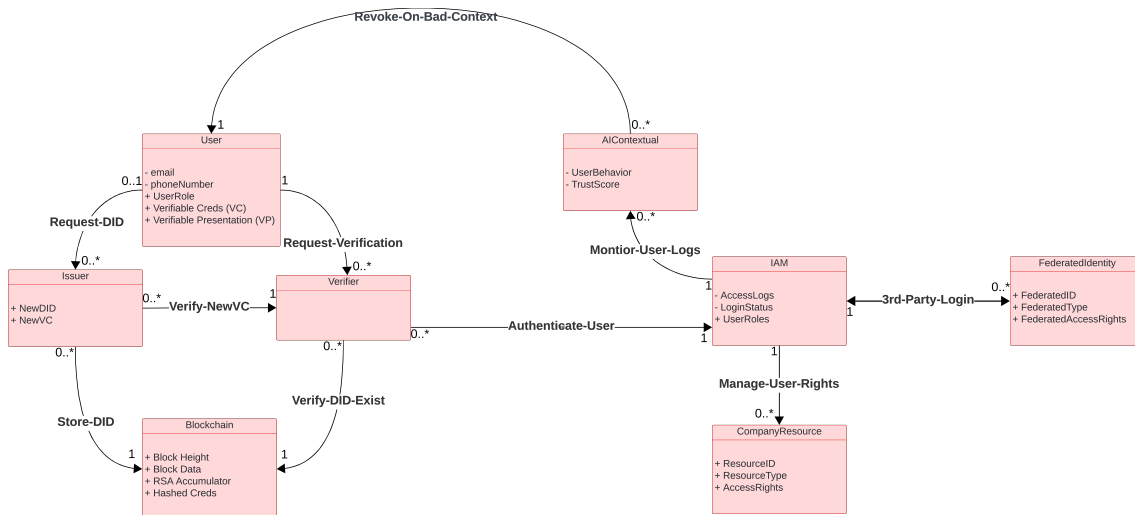


Figure 2.1: DM-001 - Domain Model Diagram

Chapter 3

System Overview

3.1 Architectural Design

3.1.1 Application Layer

1. **User Onboarding:** This module is responsible for onboarding users into the system, likely using a mobile-friendly interface that enables **passwordless login**, **Multi-Factor Authentication (MFA)**, and **Federated Identity Management (FIM)**. Users can manage accounts and receive real-time notifications, as well as use **Decentralized Identifiers (DIDs)** and **Verifiable Credentials (VCs)** for secure authentication.
2. **Resource Access:** After onboarding and successful authentication, users can access resources, which might involve applications, services, or sensitive data, governed by their credentials. This access can also include **AI-based contextual monitoring** for dynamic trust scoring, user behavior analysis, and anomaly detection.

3.1.2 Verification Layer

1. **Credential Issuance:** Once the user is onboarded, credentials (which include metadata, claims, and proofs) are issued. These credentials adhere to **Verifiable Credential (VC)** standards.
2. **Credential Addition:** The issued credentials are sent to a blockchain-based system, potentially using **IPFS (InterPlanetary File System)** for decentralized storage of metadata and **RSA Accumulator** to ensure efficient cryptographic proof aggregation. A hash of the credentials is generated for later verification.
3. **Credential Verification:** When the user attempts to access resources, their verifiable credentials, including associated proofs, are checked against the blockchain

data to validate their authenticity and integrity.

3.1.3 Blockchain Layer

1. **Hashing & Storage of Credentials:** In this decentralized system, user credentials are hashed and stored in the blockchain. The **RSA Accumulator** ensures that credentials can be efficiently verified without requiring all historical data. **IPFS** is used for decentralized file storage, ensuring the scalability of the system.
2. **Blockchain Identity Management (BDIM):** This layer leverages blockchain to manage the decentralized identities, ensuring that identity and authentication data is immutable and secure. It is also compatible with **LDAP** and directory services, allowing for integration with traditional identity management solutions. Each block contains a block header and block body, ensuring that identity records remain tamper-proof.

3.1.4 AI Behavior Analysis

1. **AI Contextual Monitoring:** The system uses AI to monitor user behavior and dynamically adjust trust scores based on user context and behavior. This data influences access control and can result in access being revoked if suspicious behavior or anomalies are detected. This real-time behavior analysis ensures that access is aligned with the current risk level associated with a user's actions.

3.1.5 Flow of Events

1. **Onboarding the User:** A user registers via a mobile-friendly interface with support for passwordless authentication.
2. **Issuing Credentials:** Verifiable credentials (VCs) are issued to the user, containing metadata, claims, and proofs.
3. **Adding Credentials to Blockchain:** The credentials are added to the decentralized system, with hashes stored on the blockchain and metadata stored using IPFS.
4. **Verifying Credentials:** When a user attempts to access resources, their credentials are verified against the blockchain.
5. **Behavior Analysis:** The system uses AI to analyze user behavior, adjusting trust levels dynamically.
6. **Access Resources:** The user is granted access to resources based on their credentials and the outcome of the behavior analysis.

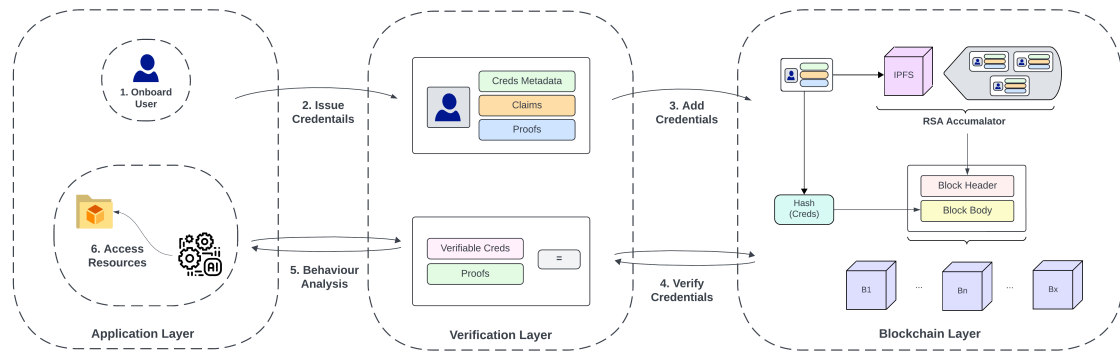


Figure 3.1: SA-001 - System Architecture Diagram

3.2 Design Models

3.2.1 Activity Diagrams for Use Cases

3.2.1.1 AD-XXX - Key

Keys:

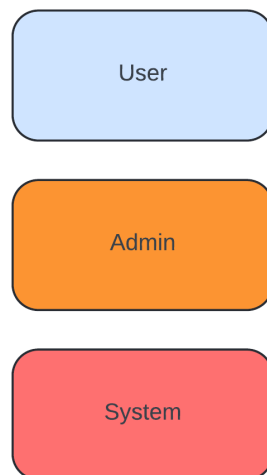


Figure 3.2: AD-XXX - Activity Diagram Key

3.2.1.2 AD-001 - User Login

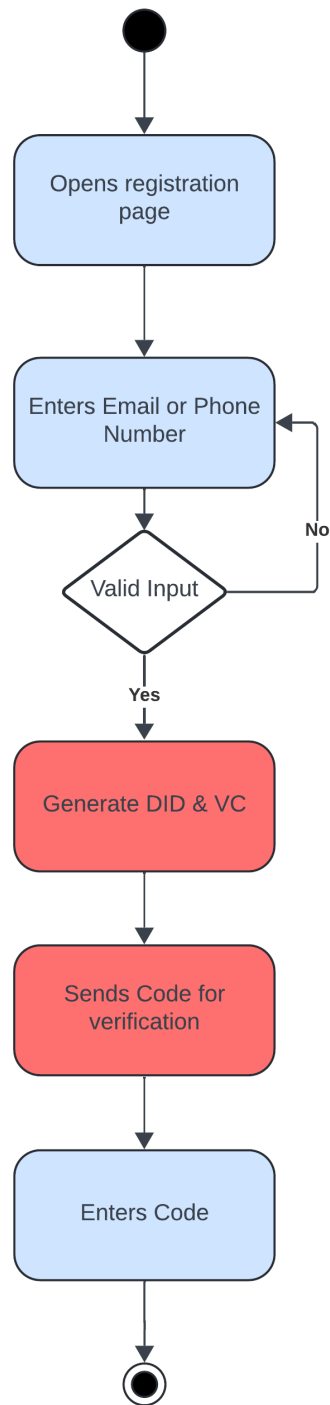


Figure 3.3: AD-001 - User Login

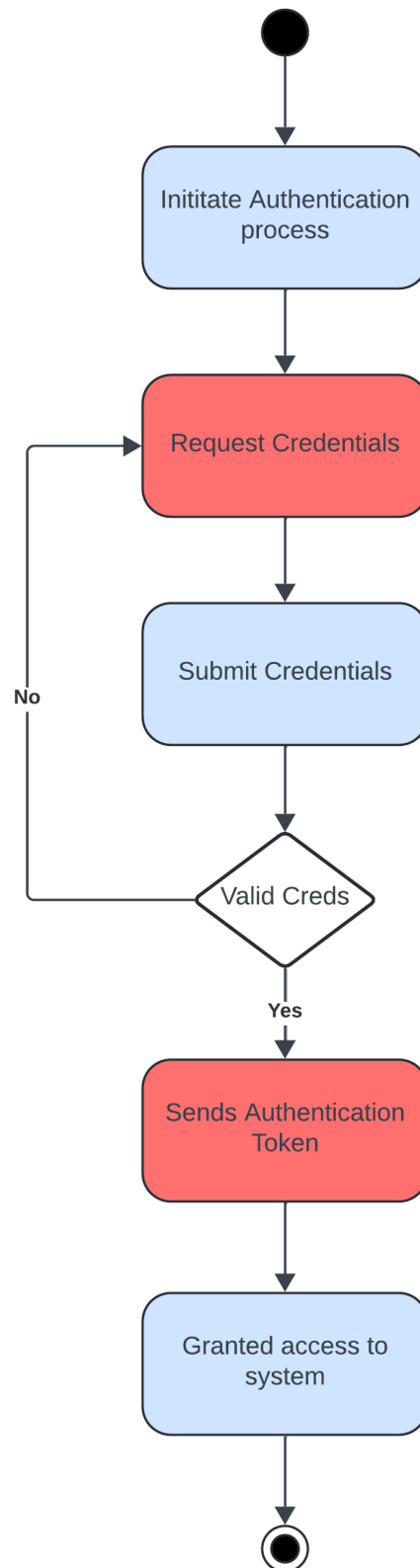
3.2.1.3 AD-002 - User Authentication

Figure 3.4: AD-002 - User Authentication

3.2.1.4 AD-003 - Administrative Dashboard Monitoring

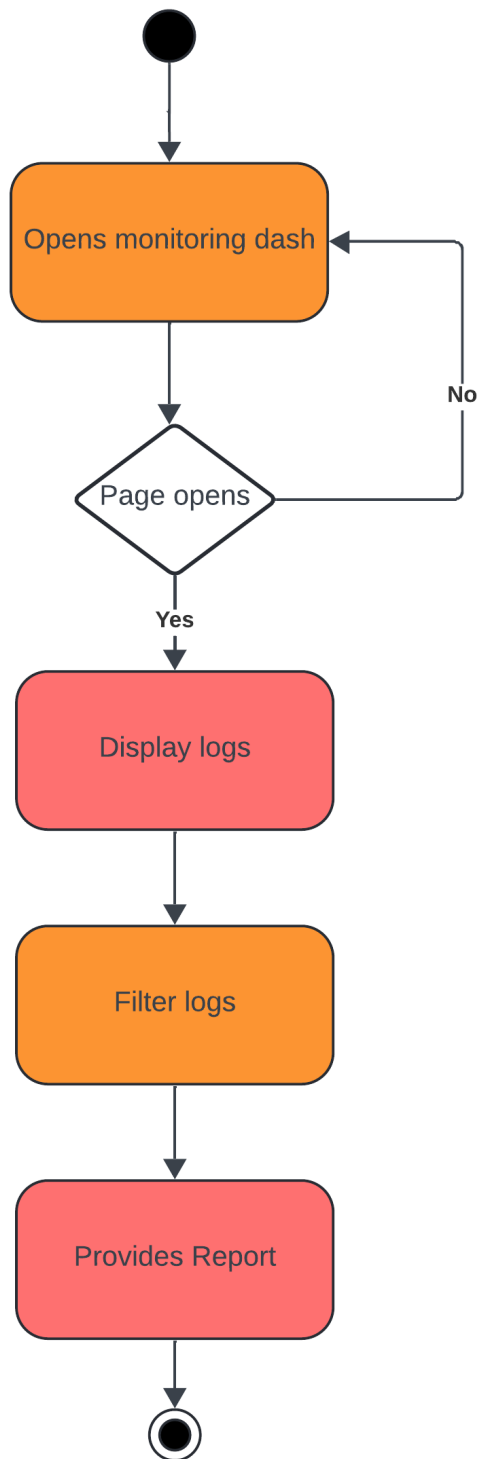


Figure 3.5: AD-003 - Administrative Dashboard Monitoring

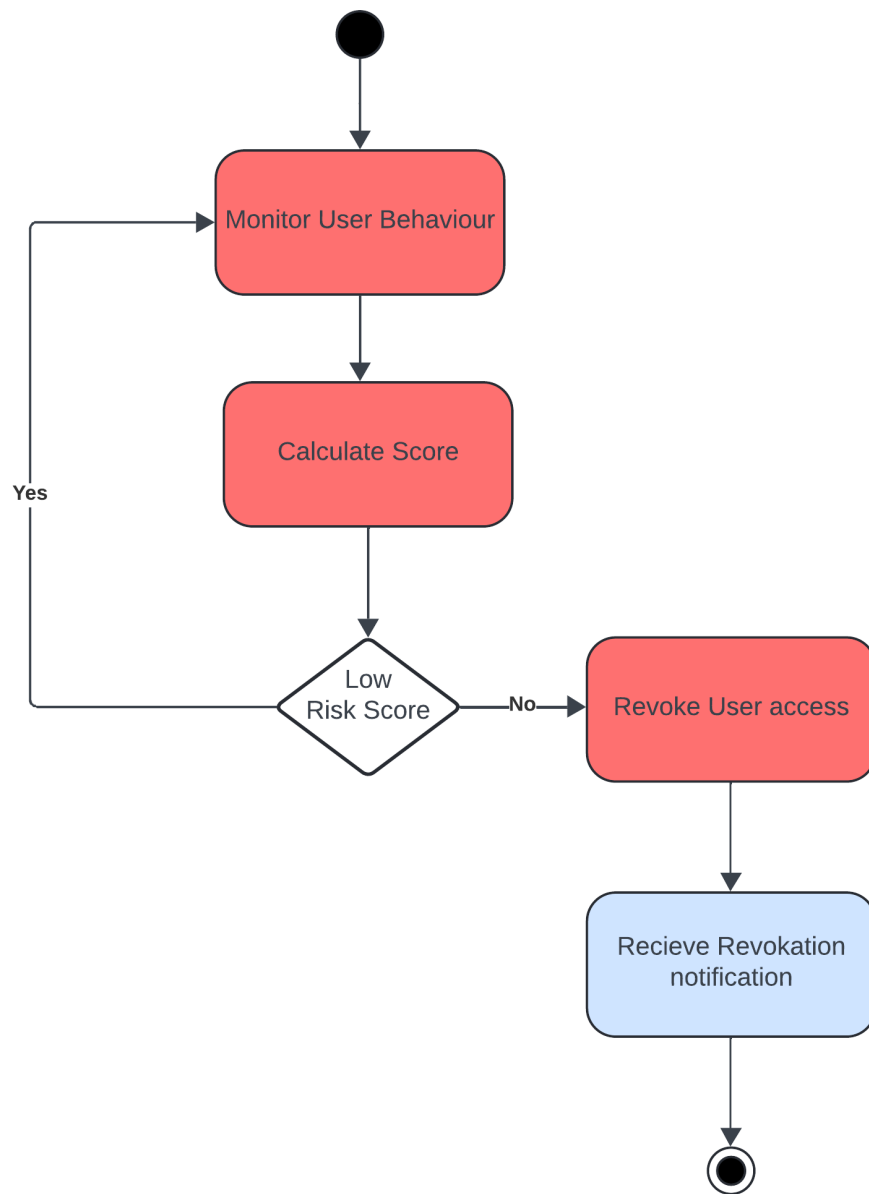
3.2.1.5 AD-004 - Trust Score Assessment

Figure 3.6: AD-004 - Trust Score Assessment

3.2.1.6 AD-005 - Blockchain-Based Identity Management

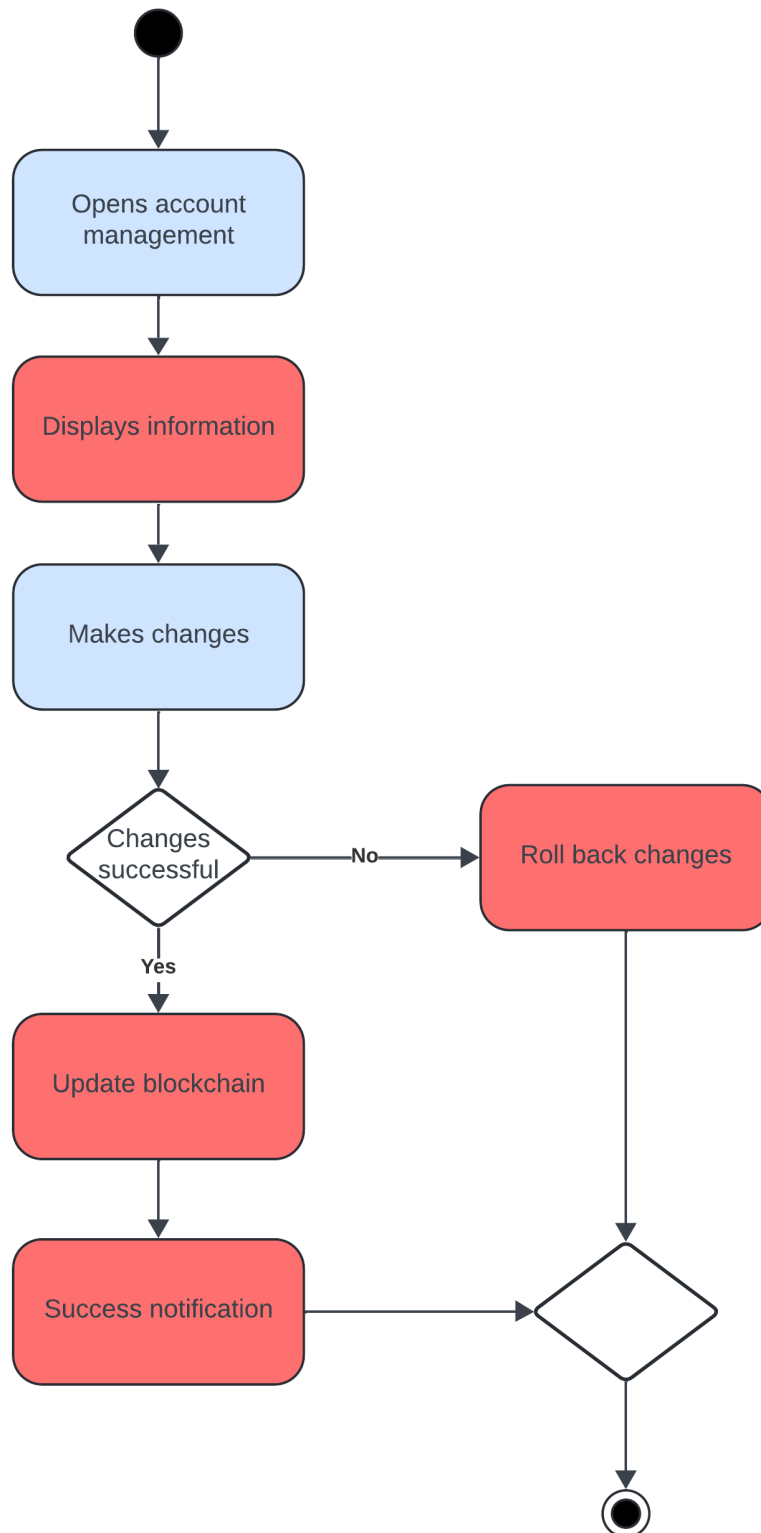


Figure 3.7: AD-005 - Blockchain-Based Identity Management

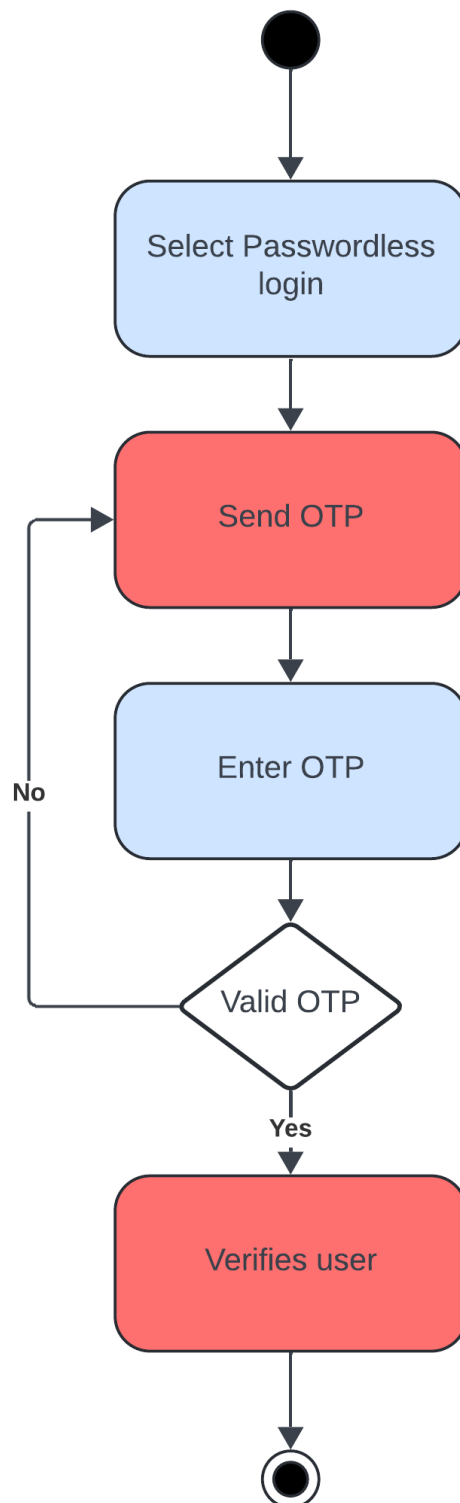
3.2.1.7 AD-006 - Passwordless Login Implementation

Figure 3.8: AD-006 - Passwordless Login Implementation

3.2.1.8 AD-007 - User Activity Log Review

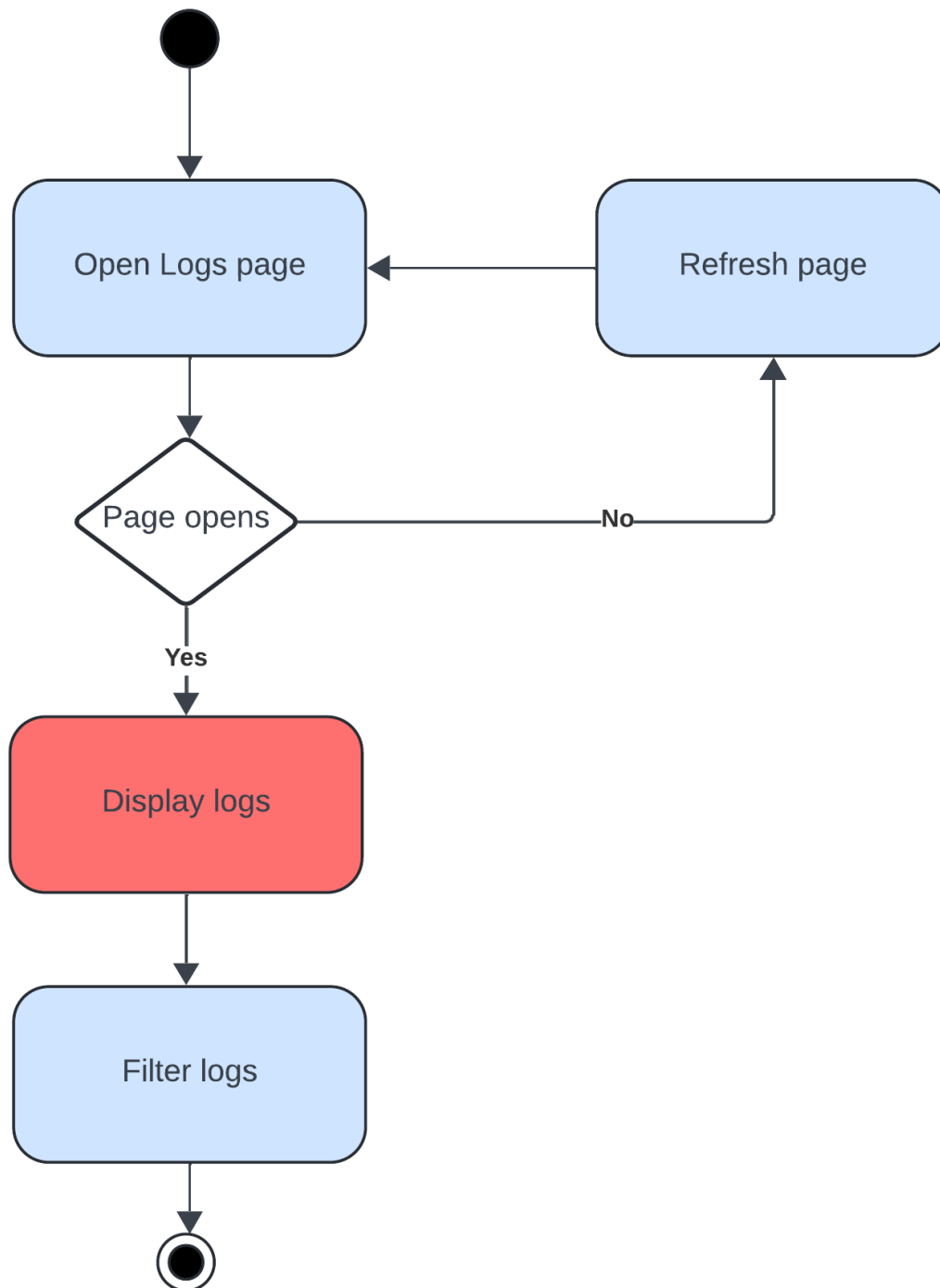


Figure 3.9: AD-007 - User Activity Log Review

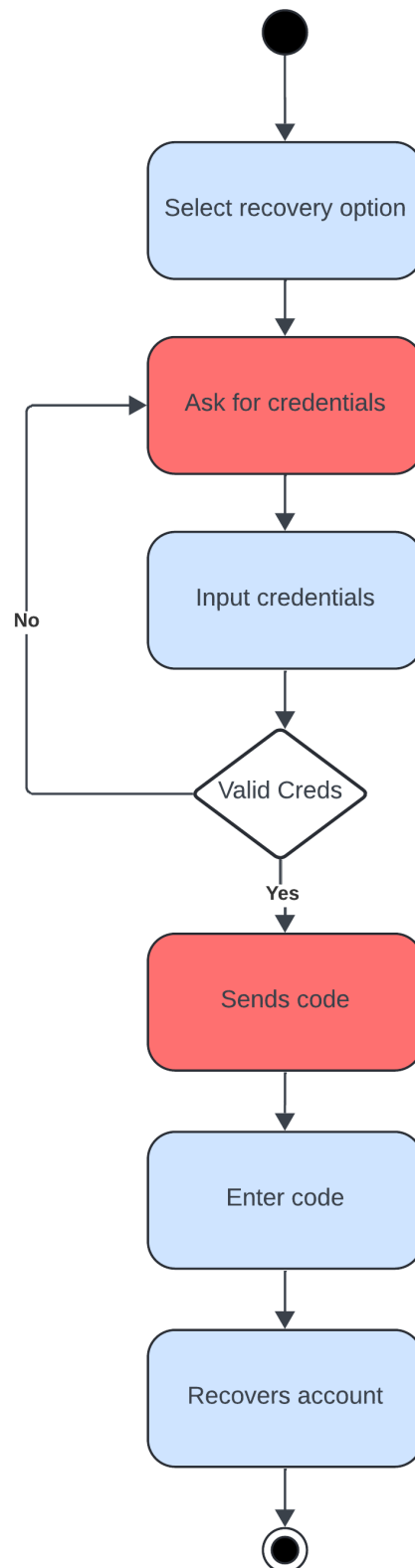
3.2.1.9 AD-008 - Account Recovery Process

Figure 3.10: AD-008 - Account Recovery Process

3.2.2 Sequence Diagrams

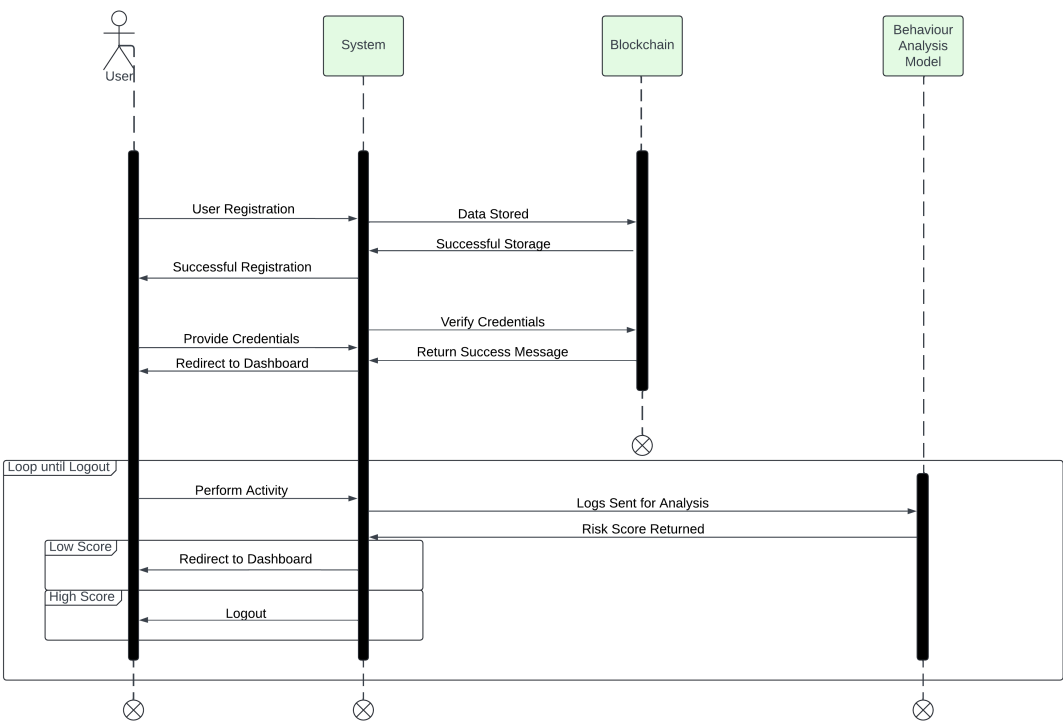


Figure 3.11: SSD-001 - System Sequence Diagram

3.2.3 Data Flow Diagram

3.2.3.1 Data Flow Diagram - Level 0

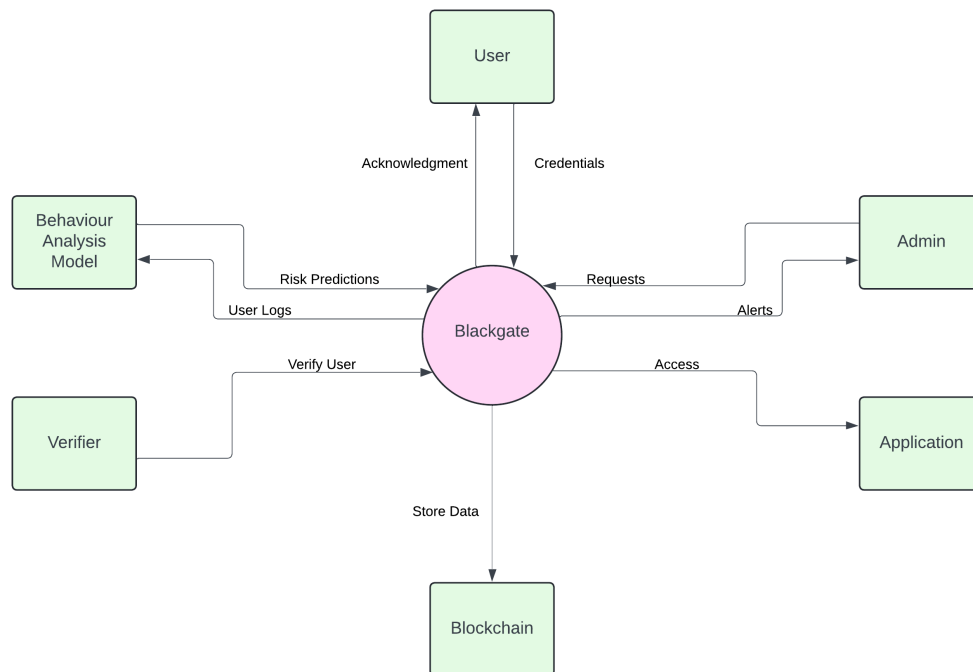


Figure 3.12: DFD-000 - Context Diagram

3.2.3.2 Data Flow Diagram - Level 1

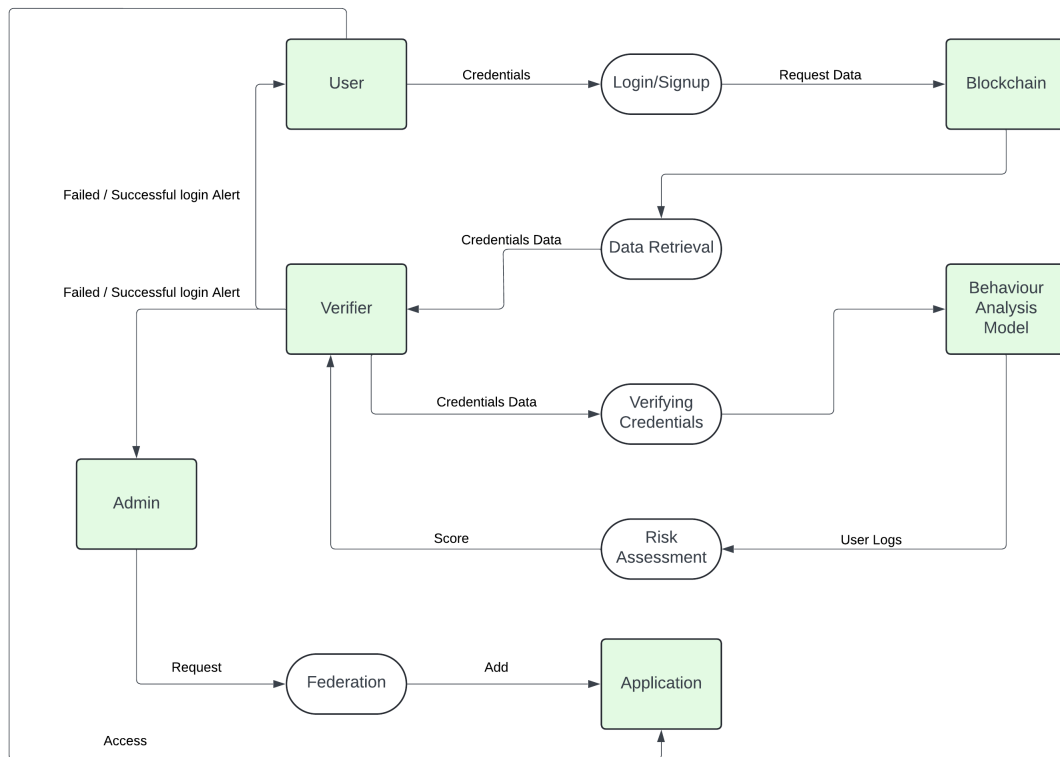


Figure 3.13: DFD-001 - Context Diagram (Exploded)

3.3 Data Design

3.3.1 Entity Relationship Diagram

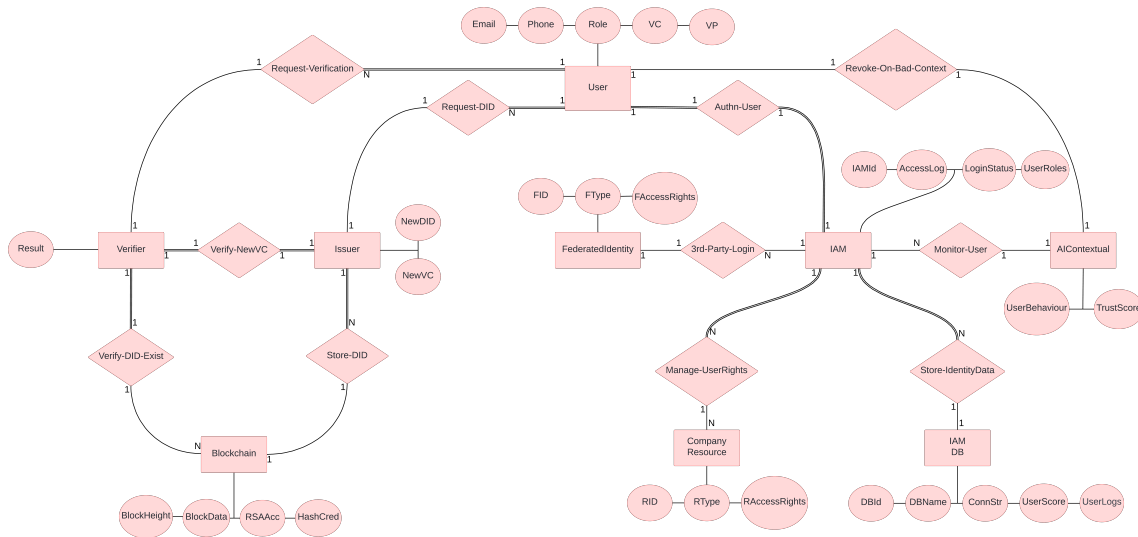


Figure 3.14: ERD-001 - Entity Relationship Diagram

Bibliography

- [1] Kening Zhang, C. K. Lee, and Yung Po Tsang. Stateless blockchain-based lightweight identity management architecture for industrial iot applications. *IEEE Transactions on Industrial Informatics*, 20(6):8394–8405, 2024.